USDT0 · SECURITY REVIEW

USDT0
XAUT0 Deployment.

A security review of XAUT0 Deployment.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
USDT0	XAUT0 Deployment	Guardian	May 14 – May 22, 2025	May 22, 2025

§ 00

Contents.

12 pages: overview, confidence ranking, scope, 4 findings, disclaimer, and about Guardian.

§ 01 **Overview** P. 03

§ 02 **Confidence Ranking** P. 04

§ 03 **Scope & Classifications** P. 05

§ 04 **Findings** P. 06

Main Review · 3 findings P. 07

Remediation Review · 1 finding P. 10

§ 05 **Disclaimer** P. 11

§ 06 **About Guardian** P. 12

§ 01

Overview.

Guardian reviewed XAUT0 Deployment across 2 review rounds. The final report includes 4 Informational findings.

AUDIT FIRM
Guardian

CLIENT
USDT0

PROJECT
XAUT0 Deployment

PREPARED BY
Guardian

AUDIT WINDOW
May 14 – May 22, 2025

FINAL REPORT
May 22, 2025

REPOSITORY
https://github.com/Everdawn-Labs/usdt0-oft-contracts, https://github.com/Everdawn-Labs/usdt0-tether-contracts-hardhat

METHODOLOGY
Smart contract · Manual · Main Review · Remediation Review

MAIN REVIEW COMMIT
528bd5f508ff

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer's assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	**0**	0	0	0	0
High	**0**	0	0	0	0
Medium	**0**	0	0	0	0
Low	**0**	0	0	0	0
Informational	**4**	0	1	0	3
All severities	**4**	**0**	**1**	**0**	**3**

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed XAUT0 Deployment in `https://github.com/Everdawn-Labs/usdt0-oft-contracts, https://github.com/Everdawn-Labs/usdt0-tether-contracts-hardhat`.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH	Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.
IMPACT · MEDIUM	Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.
IMPACT · LOW	Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.
LIKELIHOOD · HIGH	Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.
LIKELIHOOD · MEDIUM	Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.
LIKELIHOOD · LOW	Unlikely to ever occur in production.

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in. Status is where each finding ended up; its own page says how.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
I-01	OApp Owner and Delegate Address Set to an EOA Instead of a Multisig	Configuration	INFORMATIONAL	RESOLVED	p. 7
I-02	Inaccurate Block Confirmations for HyperEVM Messages	Configuration	INFORMATIONAL	RESOLVED	p. 8
I-03	Missing setTrusted Call In HyperliquidExtension	Configuration	INFORMATIONAL	ACKNOWLEDGED	p. 9
REMEDIATION REVIEW					
I-01	Bytecode Does Not Match	Configuration	INFORMATIONAL	RESOLVED	p. 10

INFORMATIONAL I-01 RESOLVED

OApp Owner and Delegate Address Set to an EOA Instead of a Multisig

CATEGORY	Configuration
LOCATION	Global
REVIEW	Main Review

DESCRIPTION

The current `owner` and `delegate` address for all the OApps deployed across the different chains is set to the externally owned address `0x565786AbE5BA0f9D307AdfA681379F0788bEdEf7`. This configuration introduces a single point of control and potential security risks across all blockchains where it is deployed. EOA-controlled addresses can be more vulnerable to key compromise or misuse by a single actor.

RECOMMENDATION

Migrate the address to a multisignature wallet to distribute control and reduce the risk of unauthorized transactions. This ensures that multiple parties approve critical operations, thereby enhancing the overall protocol security.

RESOLUTION

Status: Resolved.

Guardian: The current `delegate` address for all the OApps deployed across the different chains is still set to the externally owned address `0x565786AbE5BA0f9D307AdfA681379F0788bEdEf7`. This configuration introduces a single point of control and potential security risks across all blockchains where it is deployed. EOA-controlled addresses can be more vulnerable to key compromise or misuse by a single actor.

Recommendation
Migrate the address to a multisignature wallet to distribute control and reduce the risk of unauthorized transactions. This ensures that multiple parties approve critical operations, thereby enhancing the overall protocol security.

INFORMATIONAL I-02 RESOLVED

Inaccurate Block Confirmations for HyperEVM Messages

CATEGORY	Configuration
LOCATION	`Global`
REVIEW	Main Review

DESCRIPTION

The current LayerZero configuration sets block confirmations to 60 for any HyperEVM communication, which does not align with the actual block time requirements and risks finality issues. The desired interval for messages with this chain is half a day, equivalent to a setting of 43200 blocks.

RECOMMENDATION

Update the block confirmation value for messages sent from and to HyperEVM to 43200 to reflect half a day's worth of blocks. This adjustment ensures adequate certainty for finalizing messages.

RESOLUTION

Status: Resolved.

`https://github.com/Everdawn-Labs/usdt0-oft-contracts/pull/90/commits/ba4883ee54d18d37b10985c465505a6997757860`

INFORMATIONAL I-03 ACKNOWLEDGED

Missing setTrusted Call In HyperliquidExtension

CATEGORY	Configuration
LOCATION	https://purrsec.com/address/0xf4d9235269a96aadafc9adae454a0618ebe37949/contract
REVIEW	Main Review

DESCRIPTION

The current `HyperliquidExtension` deployed: https://purrsec.com/address/0xf4d9235269a96aadafc9adae454a0618ebe37949/contract is missing a `setTrusted` call to the `HyperLiquidComposer` contract.

RECOMMENDATION

Similarly as was performed during the USDT deployment in the following transaction: https://purrsec.com/tx/0xc3ffd03eb3295f81efefa17309e1c01601a33e365187ac6729d529ebf19659bd consider calling `setTrusted(<HyperLiquidComposer address>)` in the **XAUt0** `HyperliquidExtension`.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-01** RESOLVED

Bytecode Does Not Match

CATEGORY	Configuration
LOCATION	`Global`
REVIEW	Remediation Review

DESCRIPTION

The deployed OUpgradable contracts do not match the bytecode of the local deployments.

RECOMMENDATION

Diagnose the reason for bytecode differences.

RESOLUTION

Status: Resolved.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

$45B+
DIGITAL ASSETS UNDER REVIEW

200+
ENGAGEMENTS COMPLETED

500+
CRITICAL & HIGH FINDINGS REPORTED

Reach us at audits@guardianaudits.com.